PLATAFORMA OCR · CORVELSA · MANUAL TÉCNICO

Manual técnico de la Plataforma OCR

Cómo está construida la plataforma y cómo se instala, configura, despliega y opera: arquitectura, API, modelo de datos, procesamiento de comprobantes, seguridad y mantenimiento.

Para el uso diario de la plataforma, consulta el Manual de la Plataforma OCR (manual de usuario). Versión de octubre de 2026.

CONTENIDO

01 Propósito y alcance

02 Arquitectura

03 Tecnologías

04 Estructura del repositorio

05 Instalación local

06 Configuración

07 Autenticación y roles

08 API REST

09 Modelo de datos

10 Procesamiento de comprobantes

11 Panel de indicadores

12 Seguridad

13 Despliegue

14 Operación y mantenimiento

15 Calidad y defectos conocidos

16 Limitaciones y trabajo pendiente

01

Propósito y alcance

La Plataforma OCR es un sistema de incentivos de venta. Los participantes suben fotos o PDF de sus comprobantes de compra, el sistema extrae el texto con OCR, reconoce los productos de una campaña y acredita puntos que llevan a hitos con recompensas.

Este manual está dirigido a quien desarrolla, despliega u opera la plataforma. Describe el estado del código en la rama `master` del repositorio `FirebirdCS/Proyecto-OCR` a octubre de 2026.

Convenciones

- Los comandos se ejecutan desde la raíz del repositorio, salvo que se indique otra carpeta.
- Los comandos de PowerShell aparecen con rutas de Windows (`.\scripts\…`); los de pnpm funcionan igual en cualquier sistema.
- Los nombres de archivos, variables y rutas de la API se escriben en `monoespaciado` .

Entornos

ENTORNO	SITIO WEB	API
Local	`http://localhost:5173`	`http://localhost:4000` (Vite reenvía `/api`)
Publicado	`https://firebirdcs.github.io/Proyecto-OCR/`	`https://ocr-api-3bi5lk4hta-uc.a.run.app`

Ambos entornos usan el mismo proyecto de Firebase y Google Cloud: `proyecto-ocr-d3ecd` . No hay un proyecto de pruebas separado.

02

Arquitectura

Cliente-servidor con servicios administrados de Google. El sitio web es estático; toda escritura de datos pasa por la API, que es la única con privilegios sobre Firebase.

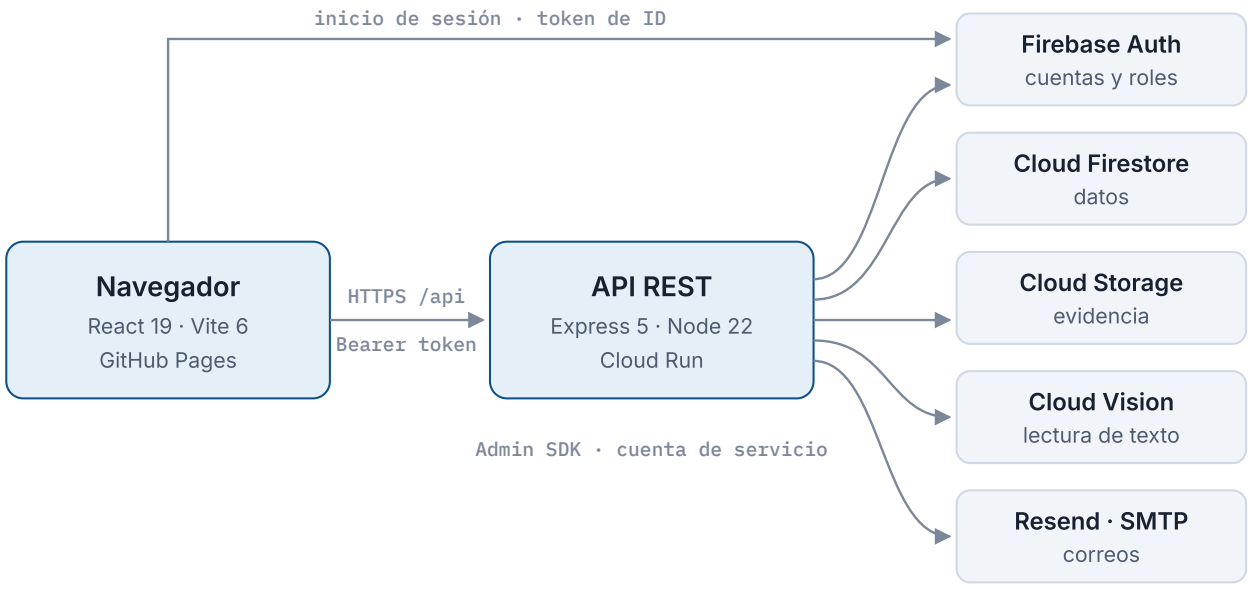


Figura 1. Componentes y comunicación. El navegador solo habla con Firebase Authentication y con la API.

Capas del servidor

CAPA	CARPETA	RESPONSABILIDAD
Rutas	`server/src/routes`	Autenticar, validar la entrada con Zod, llamar a un servicio y responder. No acceden a Firestore.
Middleware	`server/src/middleware`	`requireAuth`, `requireAdmin`, `requireRole` y el manejador central de errores.
Servicios	`server/src/services`	Reglas de negocio y todo el acceso a Firebase, Vision y correo.
Tipos y esquemas	`server/src/types`	Tipos del dominio junto a sus esquemas Zod. El cliente tiene un espejo en `client/src/types`.

CAPA	CARPETA	RESPONSABILIDAD
Utilidades	`server/src/utils`	Funciones puras: comparación de productos, revisión de comprobantes, calendario, `HttpError`.

Flujo de una petición

1. El cliente obtiene el token de ID de Firebase (`auth.currentUser.getIdToken()`) y lo envía en `Authorization: Bearer …`.
2. `requireAuth` verifica el token con el Admin SDK y deja en `req.user` el uid y el rol del claim.
3. La ruta valida el cuerpo con Zod; un error de validación se convierte en 400.
4. El servicio aplica las reglas y escribe en Firestore, casi siempre dentro de una transacción.
5. Cualquier `HttpError` llega a `errorHandler`, el único lugar que da forma a las respuestas de error.

03

Tecnologías

COMPONENTE	TECNOLOGÍA	USO
Lenguaje	TypeScript 5.8 (ESM)	Cliente y servidor.
Gestor de paquetes	pnpm 11.15.1, espacios de trabajo	Paquetes `@ocr/client` y `@ocr/server`.
Entorno de ejecución	Node.js ≥ 22.13	pnpm 11 usa `node:sqlite`, que no existe en Node 20.
Interfaz	React 19, Vite 6, React Router 7	Aplicación de una sola página.
API	Express 5, Zod 3, Helmet, Multer	REST, validación, cabeceras de seguridad y carga de archivos.
Identidad	Firebase Authentication	Correo y contraseña; roles en custom claims.
Datos	Cloud Firestore	Usuarios, productos, campañas, comprobantes, estadísticas.
Archivos	Cloud Storage	Evidencia de cada comprobante escaneado.
OCR	Google Cloud Vision 5	`documentTextDetection` para imágenes y `batchAnnotateFiles` para PDF.
Correo	Resend y Nodemailer (SMTP)	Invitaciones y envío de credenciales.
Alojamiento	Cloud Run y GitHub Pages	API en contenedor; sitio estático publicado con GitHub Actions.

04

Estructura del repositorio

```
Proyecto-OCR/
├─ client/                    Aplicación web (React)
│  └─ src/
│     ├─ components/          admin/, dashboard/, layout/, ui/
│     ├─ context/             AuthContext (sesión y rol), ThemeContext
│     ├─ lib/                 firebase.ts, etiquetas, formato, navegación
│     ├─ pages/               Login, Dashboard, Forbidden
│     ├─ services/api.ts      Cliente de la API (añade el token)
│     ├─ styles/              tokens, base, componentes, layout
│     └─ types/               Espejo de los tipos del servidor
├─ server/                    API (Express)
│  └─ src/
│     ├─ config/              env.ts (variables), firebase.ts (Admin SDK)
│     ├─ middleware/          auth.ts, errorHandler.ts
│     ├─ routes/              ocr, campaigns, mail, credenciales, admin/*
│     ├─ services/            scoring, ocr, campaigns, products, users, stats…
│     ├─ scripts/             create-user.ts, grant-role.ts
│     ├─ types/               campaigns, roles, scoring (+ esquemas Zod)
│     └─ utils/               receiptMatching, receiptChecks, calendar
├─ samples/                   Comprobantes de prueba y su generador
├─ scripts/                   deploy-api.ps1, set-resend-key.ps1, Jira
├─ docs/                      Manuales, capturas, plan de pruebas
├─ firestore.rules · firestore.indexes.json · storage.rules · firebase.json
├─ Dockerfile · .dockerignore            Imagen de la API para Cloud Run
├─ .github/workflows/pages.yml           Publicación del sitio
└─ package.json · pnpm-workspace.yaml · .nvmrc
```

05

Instalación local

Requisitos

- Node.js 22.13 o superior (`.nvmrc` fija la versión 22) y pnpm 11.15.1.
- Acceso al proyecto de Firebase `proyecto-ocr-d3ecd`, con la API de Cloud Vision habilitada.
- Una llave de cuenta de servicio del Admin SDK guardada como `server/serviceAccount.json` (Firebase Console → Configuración del proyecto → Cuentas de servicio → Generar nueva clave privada).
- Python 3 y Microsoft Edge, solo para generar los comprobantes de prueba.

Pasos

1. Instala dependencias: `pnpm install`.
2. Copia `server/.env.example` a `server/.env` y `client/.env.example` a `client/.env`. Completa los valores (capítulo 6).
3. Inicia ambos paquetes: `pnpm dev`. El sitio queda en `http://localhost:5173` y la API en `http://localhost:4000`.
4. Crea el primer administrador: `pnpm user:create correo@empresa.com admin "Nombre"`. El comando imprime el enlace para elegir contraseña.
5. Genera comprobantes de prueba: `python samples\generate_samples.py` (agrega `--limites` para los de valores límite).

> **Errores de proxy al arrancar**
> Vite suele estar listo antes que la API. Las primeras peticiones pueden registrar `http proxy error … ECONNREFUSED`; desaparecen al recargar la página una vez que aparece `API listening on http://localhost:4000`.

Comandos

COMANDO	HACE
`pnpm dev`	API y sitio juntos, con recarga en caliente.
`pnpm build`	Compila la API (`server/dist`) y el sitio (`client/dist`).
`pnpm typecheck`	Revisión de tipos de ambos paquetes.

COMANDO	HACE
`pnpm start`	Ejecuta la API compilada.
`pnpm user:create <correo> <admin|user> ["Nombre"]`	Crea una cuenta e imprime su enlace de invitación.
`pnpm role:grant <correo> <admin|user>`	Cambia el rol de una cuenta por correo.

06

Configuración

El servidor valida sus variables con Zod al arrancar (`server/src/config/env.ts`) y se detiene si alguna es inválida. Una variable vacía (`FOO=`) se trata como no definida.

Servidor (`server/.env`)

VARIABLE	PARA QUÉ	POR DEFECTO
`NODE_ENV`	`development`, `test` o `production`.	`development`
`PORT`	Puerto de la API. Cloud Run lo define.	4000
`CLIENT_ORIGIN`	Orígenes permitidos por CORS, separados por comas.	`http://localhost:5173`
`CLIENT_APP_URL`	Dirección pública del sitio, con su subruta; se usa en los enlaces de invitación.	El primer origen
`APP_NAME`	Nombre en los correos.	`OCR Platform`
`GOOGLE_APPLICATION_CREDENTIALS`	Ruta a la llave de servicio (solo local).	—
`FIREBASE_PROJECT_ID`, `FIREBASE_CLIENT_EMAIL`, `FIREBASE_PRIVATE_KEY`	Alternativa a la llave en archivo.	—
`BOOTSTRAP_ADMIN_EMAILS`	Correos que recuperan el rol de administrador al iniciar sesión.	Vacío

VARIABLE	PARA QUÉ	POR DEFECTO
`VISION_KEY_FILE`	Llave separada para Vision, si no se usa la misma cuenta.	—
`OCR_MAX_UPLOAD_MB`	Tamaño máximo del archivo.	10
`STATS_TIME_ZONE`	Zona IANA en que se cortan los días del panel.	La del servidor
`FIREBASE_STORAGE_BUCKET`	Bucket de la evidencia. Vacío: no se guarda.	—
`SCAN_DAILY_LIMIT`	Escaneos por usuario en 24 horas móviles.	20
`RECEIPT_MAX_UNITS`	Unidades máximas por comprobante y campaña.	50
`SMTP_HOST`, `SMTP_PORT`, `SMTP_SECURE`, `SMTP_USER`, `SMTP_PASSWORD`, `MAIL_FROM`	Correo por SMTP. Sin `SMTP_HOST`, el enlace de invitación se muestra en pantalla.	Puerto 587
`RESEND_API_KEY`, `RESEND_FROM`	Correo de credenciales por Resend.	`CORVELSA <info@corvelsa.com>`

Cliente (`client/.env`)

VARIABLE	PARA QUÉ
`VITE_FIREBASE_API_KEY`, `…_AUTH_DOMAIN`, `…_PROJECT_ID`, `…_STORAGE_BUCKET`, `…_MESSAGING_SENDER_ID`, `…_APP_ID`	Configuración web de Firebase. Es pública: viaja en el JavaScript del sitio.

VARIABLE	PARA QUÉ
`VITE_FIREBASE_MEASUREMENT_ID`, `VITE_FIREBASE_DATABASE_URL`	Opcionales.
`VITE_API_BASE_URL`	Dirección de la API publicada. Vacía en local (se usa el proxy de Vite).
`VITE_BASE`	Subruta del sitio; GitHub Actions la fija en `/Proyecto-OCR/`.

07

Autenticación y roles

Hay dos roles, `admin` y `user`. La fuente de verdad es el **custom claim** `role` del token de Firebase.

El rol también se copia en `users/{uid}`, pero solo para listar y buscar cuentas. Ninguna decisión de autorización lee esa copia. El mismo claim se aplica en tres lugares sin consultas adicionales:

1. La API, con `requireAuth`, que decodifica el token.
2. Las reglas de Firestore, con `request.auth.token.role`.
3. El cliente, con el token decodificado en `AuthContext`, que decide el menú y las rutas.

Reglas

- **Sin registro público.** Las cuentas las crea un administrador (`POST /api/admin/users`) o la terminal (`pnpm user:create`). Se asigna una contraseña aleatoria que nadie ve y se envía un enlace de restablecimiento; nunca se envía una contraseña.
- **Mensaje de acceso genérico.** El inicio de sesión responde igual a un correo inexistente que a una contraseña incorrecta, para no revelar qué cuentas existen.
- **Propagación.** Un cambio de rol tarda hasta una hora en llegar al token. El cliente fuerza la renovación con `refreshRole()` cuando `/api/me` devuelve un rol distinto.
- **Protección contra bloqueo.** Un administrador no puede quitarse su rol ni deshabilitarse. `BOOTSTRAP_ADMIN_EMAILS` devuelve el rol de administrador a esos correos al iniciar sesión.
- **Solo el rol `user` escanea.** `POST /api/ocr` usa `requireRole('user')`; un administrador no puede acreditarse puntos.

08

API REST

Todo vive bajo `/api`. El árbol `/api/admin` se protege en un solo lugar (`adminRouter.use(requireAuth, requireAdmin)`), así que no se debe montar ahí nada que deba ser público.

MÉTODO Y RUTA	ACCESO	HACE
`GET /health`	Público	Estado y tiempo en línea.
`GET /me`	Con sesión	Crea el perfil en el primer acceso y devuelve el rol efectivo.
`POST /ocr`	Rol `user`	Multipart con `file` y `campaignId`. Lee y califica el comprobante.
`GET /ocr/documents`	Con sesión	Comprobantes del usuario.
`GET /campaigns`	Con sesión	Campañas activas del usuario, su avance y los nombres de producto.
`POST /mail/send`	Con sesión	Envía un correo por SMTP (ver capítulo 12).
`POST /enviar-credenciales`	Admin	Envía por Resend el usuario y un enlace para fijar contraseña a una cuenta existente.
`GET · POST /admin/users`	Admin	Lista (paginada por `pageToken`) y crea cuentas.
`POST /admin/users/:uid/invite`	Admin	Reenvía la invitación con un enlace nuevo.
`PATCH /admin/users/:uid/role` · `/disabled`	Admin	Cambia el rol o habilita y deshabilita.
`GET · POST · PATCH · DELETE /admin/products`	Admin	Catálogo. Eliminar responde 409 si una campaña en borrador o activa usa el producto.

MÉTODO Y RUTA	ACCESO	HACE
`GET · POST /admin/campaigns`, `GET · PUT · DELETE /admin/campaigns/:id`	Admin	Campañas. `PUT` reemplaza la campaña completa.
`PATCH /admin/campaigns/:id/status`	Admin	Cambia el estado; activar exige un producto y un hito.
`GET /admin/dashboard`	Admin	Indicadores del panel.
`GET /admin/scans`	Admin	Comprobantes recientes; `?flagged=true` y cursor `?before=`.
`GET /admin/scans/:id/file`	Admin	URL firmada de 10 minutos al archivo original.
`POST /admin/scans/:id/void`	Admin	Anula un comprobante con puntos. Cuerpo: `{"reason": "…"}` (3 a 300 caracteres).

Errores

Las respuestas de error tienen la forma `{"error": "mensaje", "details": {…}}`. Cuando el cliente necesita un texto propio, `details.code` trae un código estable:

ESTADO	CÓDIGO	CUÁNDO
400	—	Entrada inválida (Zod) o archivo de tipo no admitido.
401	—	Sin token o token inválido.
403	`not_participant`	El usuario no participa en la campaña. También 403 sin código cuando el rol no alcanza.
404	—	Recurso inexistente o ruta desconocida.
409	`campaign_not_running`	Campaña no activa o fuera de su período.
409	`duplicate_receipt`	El comprobante ya acreditó puntos.
409	`already_voided`, `not_scored`	Anulación repetida o de un comprobante sin puntos.

ESTADO	CÓDIGO	CUÁNDO
409	—	Campaña archivada (solo lectura), activa al eliminar, producto en uso.
429	`daily_limit`	Se alcanzó `SCAN_DAILY_LIMIT`.
502	—	Error de Cloud Vision.
503	—	Falta un índice de Firestore (`FAILED_PRECONDITION`).

09

Modelo de datos

Colecciones de Firestore

COLECCIÓN	CONTENIDO	LECTURA DESDE EL NAVEGADOR
`users/{uid}`	Perfil: correo, nombre, rol (copia), fechas.	El propio usuario y los administradores.
`products/{id}`	Nombre, SKU opcional, puntos por unidad, activo.	Cualquier sesión.
`campaigns/{id}`	Nombre, descripción, estado, fechas, productos con sus puntos y mínimos, hitos, participantes y `productIds` (copia plana para consultas).	Participantes y administradores.
`campaigns/{id}/participants/{uid}`	Puntos, unidades por producto, hito, `requirementsMet`, comprobantes.	El propio usuario y los administradores.
`documents/{id}`	Cada escaneo: dueño, archivo, hash, texto, resultado, problemas, marcas, `flagged`, anulación.	El dueño y los administradores.
`salesDaily/{AAAA-MM-DD}`	Unidades, puntos y comprobantes del día, por producto.	Solo administradores.
`receiptGuards/{tipo-hash}`	Huellas para detectar duplicados.	Nadie (solo el servidor).

Ninguna escritura del navegador está permitida (`allow write: if false` en todas las colecciones). Toda modificación pasa por la API con el Admin SDK, que no está sujeto a las reglas.

Índices compuestos

COLECCIÓN	CAMPOS	LO USA
documents	`ownerUid` ↑, `createdAt` ↓	Comprobantes de un usuario y límite diario.
documents	`flagged` ↑, `createdAt` ↓	Filtro «Para revisar».
products	`active` ↑, `name` ↑	Productos activos ordenados.
campaigns	`status` ↑, `createdAt` ↓	Lista por estado.
campaigns	`status` ↑, `participantUids` (contiene)	Campañas de un usuario.
campaigns	`status` ↑, `productIds` (contiene)	Bloqueo de eliminación de productos.

Cloud Storage

Cada archivo escaneado, con o sin puntos, se guarda en `receipts/{uid}/{documentId}.{ext}` del bucket `proyecto-ocr-d3ecd.firebasestorage.app`. `storage.rules` niega todo acceso desde el navegador; los administradores ven los archivos con URL firmadas de 10 minutos.

10

Procesamiento de comprobantes

`POST /api/ocr` recorre estos pasos. Los primeros se ejecutan antes de llamar a Vision, así que un escaneo rechazado ahí no tiene costo.

1. **Rol y archivo.** Solo el rol `user`; Multer acepta PNG, JPEG, WebP, TIFF y PDF hasta `OCR_MAX_UPLOAD_MB`.
2. **Campaña.** `assertCanScan`: el usuario debe participar (403) y la campaña debe estar activa y con `startsAt ≤ ahora < endsAt` (409).
3. **Límite diario.** Cuenta todos los escaneos de 24 horas móviles; al llegar a `SCAN_DAILY_LIMIT` responde 429. Si falta el índice, el límite se omite y se registra un error.
4. **Archivo repetido.** Si el hash SHA-256 del archivo ya tiene guarda, 409 sin llamar a Vision.
5. **OCR.** Vision devuelve palabras con su geometría. `rebuildLines` endereza la página según el ángulo medio de las palabras y reconstruye los renglones, porque Vision separa las columnas del ticket y alejaría cada precio de su producto. De un PDF se leen las primeras 5 páginas.
6. **Revisión del comprobante** (`receiptChecks.ts`): debe tener una línea TOTAL con importe (en la línea o en las dos siguientes) y una fecha dentro de [inicio de la campaña, min(fin, hoy)], en `STATS_TIME_ZONE`. Si falla, 0 puntos.
7. **Productos** (`receiptMatching.ts`): solo los de la campaña elegida y activos. Ignora espacios, puntuación y acentos; tolera un error en nombres de 5+ letras (dos en 12+); las cifras deben coincidir exactamente; el SKU se compara exacto; si varios coinciden, gana el más largo. Una línea sin importe no cuenta.
8. **Cantidades.** Reconoce «2 × 15.00», «x2», «3 un», «cant: 2» o un número al inicio. Ante la duda cuenta 1 unidad: dar de menos es el fallo elegido. El total se recorta a `RECEIPT_MAX_UNITS`.
9. **Transacción.** En una sola transacción se escriben el documento, el avance del participante (puntos = unidades × puntos de la campaña, hito, requisitos), las guardas y los totales de `salesDaily`. El archivo se sube antes y se borra si la transacción falla.

Guardas contra duplicados

Solo se escriben para comprobantes que acreditaron puntos, así que uno rechazado puede volver a enviarse con una foto mejor.

- `file-<sha>`: el mismo archivo.
- `text-<sha>`: el mismo texto normalizado.

- `receipt-<sha>`: fecha, total y número de ticket (o la hora, o los productos y cantidades). Detecta una foto nueva del mismo papel, desde cualquier cuenta. Si el OCR lee mal un dígito, la guarda falla y queda la revisión manual.

Marcas de revisión

No cambian los puntos; envían el comprobante al filtro «Para revisar»: `units_capped`, `large_line_quantity` (10 o más unidades en una línea), `frequent_scanner` (cinco escaneos previos en 24 horas) y `file_not_stored`.

Anulación

`POST /admin/scans/:id/void` resta los puntos, unidades, hito y requisitos del participante y los totales de `salesDaily` del día del escaneo, y registra quién anuló, cuándo y por qué. Las guardas se conservan: un comprobante anulado no puede volver a subirse.

11

Panel de indicadores

Cada comprobante acreditado incrementa el documento `salesDaily/{día}`, con el día cortado en `STATS_TIME_ZONE`. `GET /api/admin/dashboard` lee como máximo unos 365 de esos documentos y arma tres series: 30 días, 12 semanas (desde el lunes) y 12 meses, más los productos más vendidos de cada periodo. Nunca recorre `documents`.

> **Límite de escritura**
>
> Todos los escaneos de un día escriben el mismo documento, lo que limita el ritmo sostenido a cerca de un comprobante acreditado por segundo. Si el volumen crece, hay que repartir el contador en varios documentos.

12

Seguridad

Controles

- **Secretos fuera del repositorio.** `server/serviceAccount.json` y `server/.env` están en `.gitignore`. La configuración web de Firebase (`client/.env`) es pública por diseño.
- **Sin llave en producción.** En Cloud Run la API corre como la cuenta de servicio del Admin SDK y obtiene credenciales del entorno. `GOOGLE_APPLICATION_CREDENTIALS` y `VISION_KEY_FILE` deben quedar sin definir allí.
- **Escrituras solo por la API.** Reglas de Firestore y Storage niegan toda escritura desde el navegador.
- **Cabeceras y CORS.** Helmet en todas las respuestas; CORS limitado a `CLIENT_ORIGIN`.
- **Validación en el servidor.** Las reglas de campaña (fechas, productos repetidos, hitos ascendentes, mínimos, productos activos) viven en `campaignInputSchema`; el formulario solo las refleja.
- **Evidencia privada.** Archivos solo accesibles con URL firmadas de 10 minutos.
- **Clave de Resend** en Secret Manager (`resend-api-key`), cargada con `scripts\set-resend-key.ps1`, que la pide sin mostrarla.

Observaciones abiertas

HALLAZGO	RIESGO	RECOMENDACIÓN
`POST /api/mail/send` acepta cualquier sesión, con destinatario y contenido libres.	Si SMTP está configurado, cualquier participante podría enviar correos a nombre de la plataforma.	Restringirlo a administradores o retirarlo si no se usa.
No consta que `firestore.rules` esté desplegado.	Si el proyecto tiene reglas abiertas, un usuario podría leer o escribir directamente en Firestore.	`npx firebase-tools deploy --only firestore:rules` y verificarlo con el caso CP-40.
La API acepta cualquier cambio de estado de campaña (p. ej. Borrador → Archivada), aunque la interfaz solo ofrece Borrador → Activa → Archivada → Borrador.	Estados inconsistentes con el ciclo de vida documentado.	Validar las transiciones permitidas en `setCampaignStatus`.

HALLAZGO	RIESGO	RECOMENDACIÓN
La llave local de la cuenta de servicio no tiene rotación programada.	Una copia expuesta da acceso total al proyecto.	Rotarla periódicamente y al cambiar el equipo.

El análisis de riesgos del OCR (precisión, fraude, dependencia de Vision) está en el capítulo 15 del manual de usuario.

13

Despliegue

API en Cloud Run

Servicio `ocr-api`, región `us-central1`, cuenta `firebase-adminsdk-fbsvc@proyecto-ocr-d3ecd.iam.gserviceaccount.com`. Con la CLI de Google Cloud instalada y `gcloud auth login` hecho:

```
.\scripts\deploy-api.ps1 -SkipSetup `
  -ClientOrigins http://localhost:5173,https://firebirdcs.github.io `
  -ClientAppUrl https://firebirdcs.github.io/Proyecto-OCR
```

- Construye la imagen desde el `Dockerfile` (`node:22-slim`, pnpm 11.15.1, solo dependencias de producción) y despliega con 1 GiB de memoria, 120 s de tiempo máximo y hasta 3 instancias.
- Sin `-SkipSetup` (primera vez) habilita Cloud Run, Cloud Build y Artifact Registry, y concede a la cuenta `roles/iam.serviceAccountTokenCreator` sobre sí misma. Sin ese permiso las URL firmadas de la evidencia fallan con 500.
- Parámetros: `-TimeZone`, `-ScanDailyLimit`, `-ReceiptMaxUnits`, `-BootstrapAdminEmails`, `-AppName`, `-ResendFrom`. La URL resultante queda en `scripts\.last-deploy-url.txt`.

Sitio en GitHub Pages

`.github/workflows/pages.yml` publica el sitio en cada envío a `master`. Requiere:

- **Settings → Pages → Source:** GitHub Actions.
- **Settings → Secrets and variables → Actions → Variables:** las `VITE_FIREBASE_*` y `VITE_API_BASE_URL`.
- En Firebase, `firebirdcs.github.io` en **Authentication → Settings → Authorized domains** (y `localhost` para desarrollo).

El flujo copia `index.html` como `404.html` para que los enlaces profundos funcionen en Pages.

Reglas, índices y Storage

```
npx firebase-tools deploy --only firestore:indexes,firestore:rules,storage
```

`.firebaserc` fija el proyecto. Un índice nuevo tarda unos minutos en construirse; mientras tanto, las consultas que lo necesitan responden 503.

> **Versiones de Node alineadas**
> `.nvmrc`, la imagen del `Dockerfile` y el flujo de Pages deben usar Node 22 o superior. Con Node 20, `pnpm install` falla con `ERR_UNKNOWN_BUILTIN_MODULE: node:sqlite`.

14

Operación y mantenimiento

Tareas frecuentes

TAREA	CÓMO
Ver registros de la API	`gcloud run services logs read ocr-api --region us-central1 --limit 100`
Volver a una versión anterior	`gcloud run services update-traffic ocr-api --region us-central1 --to-revisions REVISION=100`
Cambiar un límite	Redesplegar con `-ScanDailyLimit` o `-ReceiptMaxUnits`.
Rotar la clave de Resend	`.\scripts\set-resend-key.ps1`
Rotar la llave local	Generar una nueva en Firebase Console, reemplazar `server/serviceAccount.json` y borrar la anterior en Google Cloud → IAM → Cuentas de servicio.
Crear o promover un administrador	`pnpm user:create` o `pnpm role:grant`.
Regenerar comprobantes de prueba	`python samples\generate_samples.py --date AAAA-MM-DD [--limites]`

Diagnóstico

SÍNTOMA	CAUSA PROBABLE	SOLUCIÓN
Toda petición responde 401 «Invalid or expired token»	La API no encuentra credenciales (falta `serviceAccount.json` en local).	Restaurar la llave; en desarrollo `requireAuth` registra la causa real.
503 que menciona un índice	Índice no desplegado o en construcción.	Desplegar `firestore.indexes.json` y esperar.
502 «Vision API error ... PERMISSION_DENIED»	API de Cloud Vision deshabilitada o sin facturación.	Habilitarla en el proyecto.

SÍNTOMA	CAUSA PROBABLE	SOLUCIÓN
La evidencia no abre (500)	Falta `serviceAccountTokenCreator` o `FIREBASE_STORAGE_BUCKET`.	Ejecutar el despliegue sin `-SkipSetup`; revisar la variable.
El sitio publicado inicia sesión pero falla cada `/api`	`VITE_API_BASE_URL` vacía o el origen no está en `CLIENT_ORIGIN`.	Definir la variable del repositorio y redesplegar la API.
El enlace de invitación es rechazado	Dominio no autorizado en Firebase Authentication.	Agregar el dominio en Authorized domains.
Un cambio de rol «no funcionó»	Token en caché.	Cerrar sesión y volver a entrar.
El límite diario no se aplica	Falta el índice `documents (ownerUid, createdAt)`; se registra «daily limit NOT enforced».	Desplegar los índices.

15

Calidad y defectos conocidos

Material de prueba

- **Plan de QA en Jira** (espacio `SCRUM`): 11 épicas, 35 historias y 60 subtareas en tres sprints: preparación, diseño y ejecución con automatización. Fuente: `scripts/test-plan.json`.
- **Casos de prueba:** `docs/pruebas/Casos-de-Prueba-Sprint-2.xlsx`, con 41 casos, clases de equivalencia, valores límite, tablas de decisión, pairwise, transición de estados y trazabilidad.
- **Comprobantes de prueba:** `samples/`, con el resultado esperado de cada uno en `samples/README.md`.
- **Sin pruebas automatizadas todavía.** El primer objetivo recomendado es `receiptMatching.ts` (función pura, sin Firestore).

Defectos abiertos

DEFECTO	CASO
Un formato no admitido responde 400 en inglés («Expected a file upload...»).	CP-17
Un archivo de más de 10 MB responde 500: el error de Multer no se traduce en `errorHandler`.	CP-18
Un archivo de exactamente 10 MB se rechaza; el criterio dice «hasta 10 MB».	CP-18
La API acepta transiciones de estado de campaña que la interfaz no ofrece.	CP-14
`POST /api/mail/send` abierto a cualquier sesión.	—

Corregidos el 5 de octubre de 2026

Encontrados al preparar las capturas del manual de usuario:

- El botón «Quitar» de los hitos era invisible (texto rojo sobre fondo rojo): `button.danger` pintaba el fondo de la variante `ghost`.
- Los botones de ícono «Deshabilitar» y «Eliminar» aparecían como bloques rojos sólidos por la misma regla.
- En Edge, el campo de contraseña mostraba dos íconos para revelar la contraseña.
- La pantalla «No permitido» mostraba el nombre interno del rol en inglés (`user`).

16

Limitaciones y trabajo pendiente

- **Sin corrección manual de un escaneo.** Un administrador puede anular, pero no corregir una cantidad mal leída.
- **Los productos obligatorios no bloquean hitos.** Se muestran como pendientes, pero los hitos se alcanzan solo por puntos.
- **Paginación parcial.** `listUsers` y `listDocuments` tienen tope fijo; necesitarán cursores con más volumen.
- **Sin vista del avance de un participante** para el administrador.
- **Sin OCR alterno** ni reintentos si Vision falla.
- **Sin entorno de pruebas separado:** local y publicado comparten el proyecto de Firebase.
- Requerimientos del documento del proyecto sin implementación: bloqueo tras 5 intentos, expiración de sesión a 30 minutos, carga por lotes, puntos de venta, exportación a PDF/Excel, bitácora de auditoría y extracción de NIT y serie.

Manual técnico correspondiente a la versión de la plataforma de octubre de 2026.